LexFlow AI

ASSURANCE BLUEPRINT / OCTOBER 2026

EU safety, security & data protection.

A practical path to high-assurance software for German notarial workflows.

From the v0.12 prototype to a controlled, independently assessed deployment: regulatory scope, engineering safeguards, operating responsibilities and evidence for release.

PROTECT

Confidential information

VERIFY

Sources and decisions

DEMONSTRATE

Controls and evidence

Prepared for Allgift Technologies Ltd

Assessment date: 30 October 2026 | Project: v0.12.0-prototype

IMPLEMENTATION ROADMAP — NOT A CERTIFICATION OR LEGAL OPINION

01 / EXECUTIVE DECISION

A credible path to readiness.

LexFlow can be developed toward a demanding EU assurance standard. The current prototype is a starting point; compliance depends on the exact service, deployment, contracts and operating evidence.

The decision today

Continue with synthetic or fully sanitized data. Do not approve confidential notarial production use until the release gates in this report have been met. No certification, legal opinion, regulator approval or independent penetration-test result is established by this review.

There is no single universal “highest EU security” certificate. The proposed target combines applicable law, risk-based engineering, professional secrecy and independently tested operations. A feature checklist or an EU hosting address cannot establish compliance.

Workstream	What success would look like
Legal & privacy	Documented applicability, lawful processing, DPIA where required, signed processor/service agreements and a controlled data lifecycle.
Product & AI safety	Verifiable sources, meaningful human review, isolated parsing, managed keys and approved integrations that fail safely.
Operational assurance	Named accountable owners, incident response, tested restoration, independent testing and a maintained evidence register.

How to read this report

Scope and current gaps: pp. 3–6. Privacy and suppliers: pp. 7–9. AI and technical design: pp. 10–15. Operations and delivery: pp. 16–19. Control traceability and evidence: pp. 20–21. Official sources: pp. 22–24.

Status language: “Available” means found in the prototype source or documented tests; “required” means a proposed release condition unless a specific legal duty is cited; “conditional” means applicability remains to be determined. Proposed controls are not claims of completed implementation.

02 / SYSTEM & RESPONSIBILITY

Define the boundary first.

Assessment scope: LexFlow v0.12.0-prototype, its document-processing application, structured case records, file exports and optional outbound integrations. The public marketing website is separate.

CURRENT LOGICAL WORKFLOW

Documents
Local parsing and optional OCR

→

Review
Field suggestions; human confirmation

→

Handoff
Approved files; optional configured delivery

PROPOSED PRODUCTION TRUST BOUNDARIES

Office zone
Managed devices, identity and access

→

Processing zone
Isolated workers, records and keys

→

External zone
Approved providers and verified adapters

Party	Responsibility to establish
Notarial office	Normally determines the purposes of case processing: controller responsibilities, professional duties and final decisions. Confirm the actual arrangement.
Allgift / operator	Processor where it handles office data on instructions; may separately control its own business data. A software licence alone does not make the vendor a processor. [S04]
AI / hosting / support	List every recipient, subprocessor, location, privileged-access path and retention term. Actual use determines roles.

Office-owned hosting reduces some third-party access, but support, backups and external AI still need defined boundaries. NotaryDesk shares the application process and authentication; it is not independent vendor infrastructure.

Explicitly outside the delivered product

No verified ProNotar/BNotK/XNP connection, qualified signature, identity verification, AML/KYC decision, legal advice or automatic filing is supplied. Assess each future capability before enabling it.

03 / REGULATORY SCOPE

Apply the right obligations.

The assessments below are planning conclusions from the stated use case, not binding legal classifications. German counsel should confirm the exact customer and delivery model.

Instrument / status	Likely relevance and required decision
GDPR / applicable to personal data	Map purposes, lawful grounds, special categories, security, accountability, rights and recipients. Confirm the controller/processor split. [S01], [S04]
EU AI Act / use-dependent	Assess whether each mode is an AI system and whether its intended use is high-risk. Legal-office use alone does not establish Annex III status. [S07], [S08]
CRA / product-dependent	Commercially supplied connected software may be a product with digital elements. Determine manufacturer, product classification and conformity route; evaluate required remote processing. [S10]
NIS2 / entity-dependent	Assess sector, service type, size, designation and German implementing law. A notarial office or software vendor is not automatically in scope just because it handles sensitive data. [S13], [S15]
BNotO / German notarial use	Professional secrecy and service-provider access conditions must be assessed separately from GDPR processing contracts. [S16]
NotAktVV / record-dependent	Protect electronic records and respect the retention rules for the relevant file category. LexFlow is not the official electronic deed archive. [S17]
eIDAS / feature-dependent	Relevant if signatures, seals, timestamps or trust services are offered. Application approvals and hashes are not qualified trust services. [S18]

Required output: an applicability memo

Record the legal entity, product/service model, intended users, use cases, data categories, market-entry date and exact rules/version relied upon. Assign an owner and revisit the memo whenever these assumptions change.

04 / CURRENT BASELINE

Useful controls. Limited assurance.

The following controls are evidenced in project source and documentation. This PDF review did not re-run the application test suite or audit a deployed environment.

Area	Available in v0.12	Production gap
Identity	Argon2, hashed sessions, CSRF, rate limits, TOTP MFA; MFA required in hardened profile.	Managed identity, phishing-resistant MFA, recovery governance and access recertification.
Tenant / roles	Tenant-scoped records and API operations; analyst, reviewer and administrator roles.	Independent isolation testing, finer permissions and enforced separation of preparation/approval.
Approval	Human confirmation, optimistic revisions, approval gate and invalidation after changes.	Usability validation, high-impact second review and proof that the reviewed bytes match the handoff.
Encryption	Optional per-workspace encryption of original/export files; encrypted MFA secrets.	Database text, case JSON, audit details and backups need protected volumes and managed key custody.
Audit	Workspace HMAC chains, verification and checkpoint export.	External tamper-resistant retention, clock discipline and independent checkpoint custody.
Recovery / delivery	Authenticated snapshots, verified restores, durable approval-bound delivery intents.	Scheduled operations, restore drills, monitoring and real-vendor reconciliation.
AI / connectors	Local default, gated external AI; ProNotar generation disabled.	Representative accuracy evaluation, provider approval and vendor-contract testing.

Evidence: lexflow/auth.py, mfa.py, case_data.py, matter_service.py, storage.py, integrity.py, snapshots.py, delivery.py, connectors.py; deploy/compose.hardened.yml. See p. 21 for the evidence method.

05 / RISK PRIORITIES

Protect people and legal outcomes.

Priorities are proposed engineering judgements, not measured probabilities. Severity includes confidentiality, property/financial loss, procedural mistakes and loss of access to a matter.

Risk / priority	How harm could occur	Control and accountable owner
R1 / P0 Disclosure	A stolen database, backup or export reveals identities, property details or notarial secrets.	Encrypt all stores; restrict exports and key access. Security lead + operator.
R2 / P0 Wrong facts	OCR or a model changes a name, share, amount, date or property identifier.	Evidence-linked verification; no unreviewed finalization; quality gates. Product lead + notary.
R3 / P0 Privilege abuse	Cross-office access or a compromised privileged account exposes or changes records.	Test isolation; least privilege; separate privileged sessions and second review. Security lead.
R4 / P0 Malicious input	A crafted PDF/DOCX or embedded instruction attacks parsing or steers model output.	Quarantine, isolated workers, resource bounds and adversarial evaluation. Engineering lead.
R5 / P0 Unlawful external access	Cloud inference, support or logs disclose data without an acceptable legal/contractual basis.	Recipient inventory, secrecy review, DPA and transfer assessment. Controller + privacy lead.
R6 / P1 Loss / tampering	Ransomware, lost keys or altered audit history prevents trustworthy recovery.	Isolated backups, protected checkpoints and full restoration exercises. Operations lead.
R7 / P0 for integration Wrong handoff	A stale mapping, wrong recipient or uncertain retry creates a false destination record.	Verified schema/build, explicit release, idempotency and reconciliation. Integration lead.

P0: block the affected production capability until addressed and verified. **P1:** establish before live operation and prove through scheduled exercises. Do not defer recovery merely because it is labelled P1.

06 / PRIVACY BY DESIGN

Make the processing defensible.

Personal-data protection starts with an agreed purpose and a justified workflow. Software settings alone cannot provide a lawful basis.

Before an office pilot

The controller should record each processing purpose and applicable Article 6 basis; identify any Article 9 or 10 condition separately. Not all legal documents contain special-category data, but files may include health, family and criminal-history information. Do not treat the external-AI toggle as the data subject's consent or a substitute for notarial confidentiality analysis. [S01], [S16]

Prepare the processing inventory, record of processing activities and data-flow diagram. Cover originals, extracted text, candidate values, structured participants/properties, manual notes, model requests, audit history, exports, backups and support material. Identify the controller's privacy contact and determine whether a statutory DPO is required.

Data protection impact assessment (DPIA)

Screen the deployment against Article 35 and the competent authority's criteria. Where processing is likely to create high risk, complete the DPIA before it starts. If residual high risk cannot be reduced adequately, consult the supervisory authority before processing. [S03]

DPIA question	LexFlow evidence to prepare
Necessity	Why each field, document, provider and retention period is needed; less intrusive alternatives.
Risk to individuals	Wrong source choice, misidentification, unauthorized disclosure, inappropriate reuse, inability to correct records and service unavailability.
Effectiveness	Isolation tests, review usability, provider terms, data minimization, restore evidence and rights-handling exercises.

Proposed acceptance gate

The controller signs the processing/DPIA decision with advice from its DPO or privacy adviser. The engineering owner links each claimed mitigation to a tested control. Reassess for new models, providers, document families or intended uses.

07 / DATA LIFECYCLE & RIGHTS

Keep only what is justified.

Define retention by record category and legal purpose. A universal “delete everything after 30 days” setting would be unsuitable for notarial records.

Data stage	Proposed control	Evidence / owner
Intake	Collect necessary files; reject unsupported content; identify duplicates and classify sensitivity.	Intake rules and quarantine logs / engineering.
Working records	Separate source facts, suggested values and approved values; preserve revisions without unlimited copying.	Data dictionary and access rules / product.
Model requests	Minimize selected content; exclude unnecessary identifiers; prohibit training/reuse unless separately justified.	Approved provider profile and request policy / privacy.
Exports	Limit who can download; label recipients and purpose; use protected transfer and record acknowledgements.	Export register and recipient checks / office.
Logs / backups	Minimize personal content; set separate retention schedules, legal holds and backup expiry.	Retention inventory and restoration controls / operator.
Closure / deletion	Apply category-specific retention, justified holds and verifiable deletion; reapply deletion records after restore.	Deletion evidence and hold approvals / controller.

A usable rights workflow

Provide a verified request channel, identity checks, a search across relevant records and a review step that protects other parties’ information and professional secrecy. Access, rectification, restriction and erasure depend on the applicable legal conditions. Record refusals and their grounds. The usual response period is one month; permitted extensions must be communicated within that month. [S02]

Map the office’s legal retention schedule to the applicable NotAktVV file categories. A downloaded bundle remains outside LexFlow’s recall controls, so recipients need contractual and operational deletion/retention responsibilities. [S17]

08 / SUPPLIERS & PROFESSIONAL SECRECY

Control every external access.

The public website, the office application and an AI provider are distinct processing contexts. A public website’s privacy notice is not an office processing agreement.

Notarial secrecy is a separate approval

Under BNotO §26a, relevant arrangements include careful provider selection, text-form confidentiality commitments, need-to-know access and controlled subcontracting. Subsection (4) contains a separate consent rule for services directly serving an individual official act. Have qualified notarial counsel determine how this applies to the intended AI/support service before disclosure. A GDPR DPA alone does not settle it. [S16]

Contract and supplier evidence

Where the supplier is a processor, execute an Article 28 data processing agreement (DPA) describing instructions, authorized staff, subprocessors, technical measures, breach support, audit rights, deletion/return and assistance with rights. Require advance notice of material provider changes, an exit path and a named incident contact. [S04]

Boundary	Required evidence before enabling it
Inference provider	Exact endpoint, model/version, region, contractual retention, permitted reuse, subprocessors, abuse-monitoring exceptions and deletion terms. The repository proves none of these contractual assurances.
Support / hosting	Data locations plus the countries, organizations and staff permitted to access live data, backups and logs; scoped temporary support access with audit.
Non-EEA recipient	Determine whether a Chapter V transfer occurs; select and assess the applicable transfer mechanism, including safeguards where necessary. An EEA data centre alone is insufficient. [S05]

Conservative initial operating policy

Prefer an office-controlled or dedicated EEA deployment with external AI disabled. Enable a provider only after documented privacy, secrecy and security approval. This is a proposed risk-reduction policy, not a claim that GDPR always mandates EU-only hosting.

09 / EU AI ACT

Classify the use, then the duties.

This is a provisional product assessment. The intended purpose, actual configuration and organization using the output determine the legal analysis.

LexFlow presently prepares data for human review. It does not decide cases or interpret the law. That purpose does not automatically place it in Annex III. Point 8(a) concerns assistance to judicial authorities, or comparable alternative dispute resolution, in interpreting facts/law and applying law to cases. Obtain a written assessment of the exact notarial use. [S08]

If a use falls within Annex III, consider Article 6(3) only where its conditions are actually met; a human-review button is not itself an exemption. Document any conclusion that an Annex III system is not high-risk and address the applicable registration rule. Profiling changes the analysis. Reclassify when adding legal recommendations, eligibility scoring or judicial decision support. [S07]

Date / rule	Current planning position
2 August 2026	General application with exceptions; assess relevant transparency obligations and the actual deployed features. [S06]
2 December 2027	Revised application date for Annex III high-risk requirements, following the 2026 AI Omnibus. [S06]
2 August 2028	Revised date for high-risk AI embedded in regulated products. It is not LexFlow’s assumed category. [S06]
AI literacy	Maintain role-specific training, exercises and evidence. Amended Article 4 requires supporting literacy development, not guaranteeing an individual proficiency level. [S09]

If the system is high-risk

Plan the applicable provider/deployer obligations: risk and quality management, technical documentation, data governance, traceability, oversight, accuracy/cybersecurity, conformity and registration, post-market monitoring and incident handling. Assess whether the deployer also needs a fundamental-rights impact assessment. [S06]

Integrating a third-party model does not by itself establish that Allgift is the provider of that general-purpose model. Allocate system-provider, deployer, importer/representative and model-provider duties from the real supply chain.

10 / AI SAFETY & EVALUATION

A suggestion is never an authority.

The target is controlled assistance with observable failure. Confidence values in the current prototype are heuristic hints, not calibrated probabilities.

Safety control to implement	Acceptance evidence
Reliable source grounding	Page/region references for every critical value; clear distinction between extraction, manual entry and unverified model output. Missing or skipped pages trigger visible review blocks.
Meaningful human oversight	Reviewers can inspect originals, reject values, correct data and stop export. Require a second person for defined high-impact fields; test that preparation and approval cannot be silently combined.
Injection resistance	Treat document text as untrusted data. No document-provided instruction may select recipients, invoke tools, bypass review or change permissions. Test hidden text and adversarial multilingual documents.
Bounded outputs	Schema/length/type validation, explicit unknown values, conflict detection and fail-safe handling of timeouts, incomplete OCR and malformed responses.
Change control	Version rules, parser/OCR, prompts, model, schema and test corpus. Re-evaluate changes; use rollback and disablement controls.

Evaluation that matches notarial harm

Use an authorized holdout set covering document families, scan quality, languages, handwriting and conflicting sources. Measure exact field accuracy, missed conflicts, wrong identities/property identifiers, unsafe acceptance and review effort. Report sample sizes and uncertainty, not only aggregate scores.

Existing benchmark: limited but useful

The committed 28-case synthetic text benchmark records 69 true positives, 0 false positives and 2 misses (micro F1 98.6%). It excludes OCR, external AI and legal correctness. It cannot justify a real-office accuracy claim or production readiness.

11 / ACCESS & DEPLOYMENT

Use a stronger operating boundary.

The hardened container profile is a starting configuration. Its effectiveness must be demonstrated in the actual host, network and support environment.

Layer	Proposed target design
Identity	Managed SSO/OIDC, phishing-resistant MFA for privileged access, controlled recovery, short-lived sessions, device policy and prompt offboarding. Retain and independently test existing CSRF/session protections.
Authorization	Deny by default; permissions by office, matter, role and operation. Separate user administration, key custody, security review and document approval. Require explicit, audited emergency access.
Office isolation	For the initial high-assurance deployment, prefer separate office stores/keys and an isolated processing boundary. Demonstrate equivalent isolation before consolidating tenants.
Network	TLS at approved ingress, narrowly scoped service identities, outbound allowlists and separate management paths. Block unexpected destinations and metadata-service access.
Workers	Run parsers/OCR in disposable non-privileged workers with no general internet access, strict CPU/memory/time limits and no production credentials.
Host / operations	Patch and monitor hosts; protect backups and secrets outside ordinary application access; restrict production shell access and test boundary failures.

Checks against realistic abuse

Attempt cross-office object access, path traversal, forged CSRF requests, replayed sessions, unauthorized field/export changes and hostile recovery attempts. Repeat with analyst, reviewer, administrator and support identities. Include storage, logs, backups and asynchronous jobs in the assessment.

These are proposed controls; current TOTP MFA is not phishing-resistant. Dedicated infrastructure reduces shared failure modes but does not remove the need for authorization tests. UI visibility is not an access-control boundary.

12 / STORAGE, KEYS & EVIDENCE

Protect the complete record.

File encryption is only one layer. Plaintext extracted text, case JSON and audit values can be as sensitive as the original document.

Encryption and key management

Use maintained, reviewed cryptographic libraries and authenticated encryption. Protect transport and all persistent stores, including database volumes, snapshots, temporary processing files and off-site backups. Where the threat model requires it, add field/application encryption with per-office keys and deliberate search/access trade-offs.

Put production keys in a managed KMS/HSM or equivalently controlled service. Separate data, MFA, audit and transfer keys; limit decrypt permissions; log administrative use. Define rotation, revocation, compromise response and recovery with dual control. Never keep the only recovery key beside the only encrypted backup.

Current mechanism	What it proves / what it does not
SHA-256 source/bundle digest	Detects a mismatch against a trusted digest. Does not prove who approved a record, its legal truth or destination acceptance.
Per-workspace HMAC chain	Can expose altered or missing interior events if keys are protected. A privileged actor controlling local state may remove a tail; external checkpoints are required.
Review / approval event	Records a workflow decision. Is not a qualified signature, notarization or identity verification. [S18]

Defensible audit evidence

Send minimum necessary security events and trusted checkpoints to independently administered, tamper-resistant storage. Record identity, action, object/revision, source/model versions, approval, export/receipt and time. Monitor clock drift and failed verification. Limit personal content and apply a justified retention/hold policy.

Restore must preserve trust

A recovery drill must restore records and keys, verify audit continuity, revoke stale sessions and reconcile pending deliveries. Successful file decryption alone is not a successful business recovery.

13 / PRODUCT SECURITY & CRA

Secure what you ship and maintain.

Keep the production build reproducible and supportable. Every parser, package, container and update channel is part of the risk boundary.

Workstream	Proposed implementation and evidence
Upload handling	Verify file signatures and type; quarantine before parsing; malware scanning, archive expansion limits and content disarm where suitable. Preserve restricted originals without executing active content.
Secure development	Threat modelling, peer-reviewed changes, protected branches, secret/dependency scanning and targeted static/dynamic analysis. Resolve security findings before release according to risk.
Supply chain	Machine-readable SBOM, pinned inputs, provenance, integrity-protected releases and verified updates. Record dependency ownership, licences and vulnerability exposure.
Vulnerability handling	Public reporting channel, triage/on-call ownership, coordinated disclosure, patch tracking and customer notices. Validate the CRA reporting role now if in scope.
Support lifecycle	Define supported versions, updates, end-of-support communication and a funded maintenance period. Retest changes that affect safety, privacy or integrations.

Assess CRA scope and product category for commercial LexFlow distribution, including necessary remote processing. Open-source dependencies or a “SaaS” label do not settle applicability. [S10]

For an in-scope product, prepare its risk assessment, technical file, vulnerability-handling evidence and conformity process. Business software is not automatically an “important” or “critical” CRA category. Classification determines the permitted assessment route; do not claim CE marking before fulfilling it. [S10]

Dates that affect planning

CRA reporting obligations apply from 11 September 2026; the main obligations apply from 11 December 2027. These dates do not eliminate the need to establish whether the product, role and transitional rules apply. [S11]

14 / PRONOTAR & HANDOFF

Verify the destination contract.

The latest vendor-supported release is a target policy, not an identified build or import format. The current LexFlow JSON bundle is not a verified ProNotar interchange contract.

Gate	What must be demonstrated
1. Authorized interface	Obtain supported documentation, licence/permission, exact ProNotar build/modules, field semantics, import limits and acknowledgement behaviour.
2. Controlled mapping	Version the mapping for parties, representatives, shares, property identifiers, tasks and source references. Validate identifiers against appropriate authoritative sources where required.
3. Snapshot integrity	Export only the current approved revision. Bind the destination, mapping version and payload to that approval; reject stale or changed records.
4. Safe transport	Use supported, authenticated transport with protected secrets, destination allowlists and restricted accounts. Do not infer vendor support from the generic HTTPS demo.
5. Reconciliation	Test duplicate delivery, partial import, timeout after acceptance, wrong destination and retries. Obtain meaningful receipts and compare imported values with the approved snapshot.
6. Recovery	Define supported correction/reversal procedures and human handling of ambiguous outcomes. Never assume that an uncertain request failed or that every vendor offers transactional rollback.

A bounded first pilot

Start with one case type, synthetic data and a vendor-approved test environment. Have office staff inspect destination records and record discrepancies. Freeze the tested version pair and rerun contract tests after either product changes.

Production release condition

Keep the ProNotar adapter disabled until the office, integration owner and authorized vendor/interface owner accept the import evidence. Integration acceptance is separate from GDPR, notarial authority and overall security approval.

15 / RESILIENCE & INCIDENTS

Prepare the response before launch.

Create one incident register with separate legal reporting decisions. An operational outage, personal-data breach and exploitable product vulnerability can trigger different duties.

Regime / condition	Reporting decision and timing
GDPR personal-data breach	Controller: notify the competent authority without undue delay and, where feasible, within 72 hours of awareness unless risk to individuals is unlikely. Processor: inform the controller without undue delay. A likely high-risk breach also requires informing affected individuals without undue delay, subject to Article 34 exceptions. [S01], [S04]
NIS2, if the entity is covered	For a significant incident: early warning within 24 hours, notification within 72 hours, final report normally within one month of notification. Ongoing incidents and certain sectors have specific handling. Confirm German implementation and portal. [S14], [S15]
CRA, if the manufacturer is covered	Actively exploited vulnerability/severe product-security incident: early warning within 24 hours and notification within 72 hours of awareness. Vulnerability final report: within 14 days after a corrective measure is available. Severe-incident final report: within one month of the 72-hour notification. [S12]

Maintain an awareness timestamp, facts, uncertainty, affected offices/records, containment actions, evidence custody, decision owner and reporting receipts. Do not wait for the investigation to finish before considering notification; supplement initial reports as facts become available.

Recovery targets must be measured

Proposed starting objectives for office agreement: recovery point objective (RPO) ≤1 hour of lost changes; recovery time objective (RTO) ≤4 hours to restore the working case service. These are design targets, not legal deadlines or achieved service levels. Validate through complete restoration, key recovery and delivery reconciliation; retain a manual fallback.

Run quarterly restoration exercises and at least annual ransomware/breach tabletop exercises, plus retests after material changes. Use isolated backup administration, immutable/offline copies, clean recovery infrastructure and customer communication templates. These frequencies are proposed policy, not universal statutory intervals.

16 / GOVERNANCE & ASSURANCE

Assign ownership, then prove it.

Security, privacy and AI governance need funded operating roles. The names below are required functions; no named appointments or external certifications were established in this review.

Accountable function	Required evidence
Executive sponsor	Approved risk appetite, resources, scope and residual-risk decisions; no override of binding legal duties.
Notarial controller / practice lead	Lawful purpose, confidentiality decisions, review rules, record retention and operational acceptance.
Privacy adviser / DPO where required	Independent advice, DPIA and rights/transfer review; conflict-free role and escalation route.
Security / engineering lead	Threat model, secure design, vulnerability handling, control tests and release evidence.
Operations / incident lead	Access lifecycle, monitoring, backup restoration, incident drills and supplier escalation.
Independent assessor	Penetration and isolation testing with remediation retest; assess the exact deployed scope and exclusions.

Assurance targets beyond the minimum

Build an ISO/IEC 27001:2022 management system, including applicable amendments, with a risk treatment plan and Statement of Applicability. Consider ISO/IEC 27701:2025 for privacy management and ISO/IEC 42001:2023 for AI governance. Arrange appropriately scoped independent certification when the operation is ready. [S19], [S20], [S21]

Use assurance claims precisely

A management-system certificate covers its stated organizational/service scope. It is not a blanket GDPR approval, a guarantee of AI accuracy or a ProNotar certification. Publish the scope, issuer, validity and material exclusions; do not use certification badges before they are earned.

Review a proposed monthly dashboard: unresolved severe findings, access exceptions, review overrides, failed audit checks, backup/restore outcomes, incident-response performance and model/document-family drift.

17 / DELIVERY ROADMAP

Progress through evidence gates.

The phases below are a proposed sequence. Duration and cost cannot be responsibly fixed until deployment scope, team capacity, vendor access and assessor availability are known.

Phase	Deliverables	Exit decision
A / Define	Applicability memo; controller/processor map; intended-use statement; data inventory; threat model; provider constraints; budget and owners.	Controller, sponsor and counsel accept scope.
B / Harden	Complete storage/key protection; isolated parsing; managed access; least privilege; export controls; immutable evidence; secure release pipeline.	Security owner verifies controls in a representative environment.
C / Validate	Representative test corpus; AI review usability; DPIA/agreements; independent penetration and isolation test; restoration and response drills.	Remediation retested; residual risk and privacy decision documented.
D / Integrate	Verified ProNotar contract, versioned adapter and reconciliation tests, if this capability is included. Otherwise keep it disabled.	Office and integration owner accept destination evidence.
E / Pilot	Limited authorized office rollout, trained reviewers, monitored quality, rollback criteria and controlled support.	Measured results meet pre-agreed thresholds.
F / Operate	Support coverage, patching, access review, supplier monitoring, refreshed evaluation and scoped external assurance.	Recurring management review; suspend unsafe capabilities.

Resource the work explicitly

Budget for engineering, secure hosting/key management, privacy/notarial counsel, independent security testing, representative evaluation, vendor integration support and ongoing operations. A one-time build budget cannot fund continuing vulnerability and incident obligations.

Do not wait for every optional feature

A controlled local pilot may precede external AI or ProNotar integration if those capabilities remain technically disabled and the pilot’s own legal, privacy, safety and security gates are complete.

18 / RELEASE ACCEPTANCE

Make readiness a signed decision.

All proposed gates need evidence for the exact release and deployment. A passed test is evidence within its scope, not proof that a future incident is impossible.

Gate	Minimum acceptance evidence	Owner
G1 / Legal	Signed applicability and processing decisions; required DPIA, agreements, notices and transfer/secrecy approvals complete.	Controller + counsel
G2 / Identity	No demonstration accounts; MFA required; recovery and revocation tested; privileged access and second-review policy enforced.	Security
G3 / Data	Every sensitive store and backup mapped and protected; key-loss/rotation tested; rights, retention, holds and deletion exercised.	Privacy + ops
G4 / Isolation	Independent test finds no unresolved exploitable cross-office access, authorization bypass or material injection path; fixes retested.	Security
G5 / AI safety	Critical fields always reviewed; agreed accuracy/conflict thresholds met on an authorized holdout set; unsafe cases route to manual handling.	Notary + product
G6 / Recovery	Measured RPO/RTO meet agreed targets; trusted audit and pending handoffs reconcile after restore; incident drill completed.	Operations
G7 / Integration	Enabled connectors have approved destination/build/contract and passed failure/retry tests. Unverified connectors stay blocked.	Integration
G8 / Maintenance	Supported release, SBOM, update/rollback process, vulnerability reporting, trained staff and on-call ownership documented.	Engineering

Proposed release policy: remediate and retest critical/high security findings before confidential production use. Agree safety thresholds before evaluation. Zero failures in a finite test set does not mean zero risk.

Stop conditions: unexplained cross-office access, export/approval mismatch, corrupted audit evidence, uncontrolled provider disclosure or repeat critical extraction errors. Disable the affected path, preserve evidence and invoke the incident procedure.

19 / CONTROL TRACEABILITY

Connect obligations to evidence.

Use this compact matrix to seed the implementation backlog and assessment register. The status column describes this prototype review, not an assessor’s conclusion.

Requirement theme	Control / evidence to collect	Status
GDPR Arts. 5, 25, 30	Inventory, minimization, lifecycle rules and processing records; map every copy including audit/history. [S01]	Open
GDPR Arts. 28, 44–49	Role allocation, DPA, supplier inventory and relevant transfer/secrecy assessment. [S04], [S05]	Open
GDPR Art. 32	Identity/authorization, complete storage protection, resilience and verified effectiveness. [S01]	Partial
GDPR Arts. 33–36	Breach playbook, reporting decisions, DPIA screening and any required consultation. [S01], [S03]	Open
AI classification / literacy	Intended-use memo, role analysis, training and change-triggered reclassification. [S07], [S08], [S09]	Open
AI high-risk duties, if applicable	Risk/quality system, data/evaluation evidence, technical file, oversight, conformity and monitoring. [S06]	Open
CRA, if applicable	Product scope, secure lifecycle, conformity route and tested vulnerability-reporting process. [S10], [S11], [S12]	Open
NIS2, if applicable	Entity determination, governance, risk controls and significant-incident response. [S13], [S14], [S15]	Open
BNotO / NotAktVV	Secrecy arrangements, provider access restrictions and category-specific record protection. [S16], [S17]	Open
ProNotar safety boundary	Approval-bound mapping, authorized contract and destination reconciliation evidence.	Blocked

Partial means some technical mechanisms exist. **Open** means the required deployment or governance evidence was not supplied or established by this review. **Blocked** refers to an intentionally disabled unverified connector.

20 / EVIDENCE & REVIEW METHOD

Know what this report establishes.

Prepared on 30 October 2026 from the repository and official sources. This is a readiness roadmap, with no runtime changes.

Evidence group	Repository material reviewed
Security / architecture	docs/SECURITY_AND_LIMITATIONS.md; ARCHITECTURE.md; DEPLOYMENT.md; PRONOTAR_EXTENSION.md.
Control implementation	lexflow/auth.py, mfa.py, storage.py, integrity.py, snapshots.py, settings.py, extraction.py, case_data.py, matter_service.py, connectors.py and delivery.py; hardened deployment profile.
Recorded verification	docs/TEST_PLAN.md; test_case_data.py, test_mfa.py, test_snapshots.py and test_delivery.py; synthetic-v1-report.json.
Regulatory basis	Official EU Commission/EDPB/BSI and German legislation pages, plus ISO descriptions. Sources and review date follow.

Evidence limits

The project records 134 backend and 26 UI logic tests for v0.12. They were not re-run for this report. These prior results and the synthetic benchmark are not an independent audit, representative office evaluation or certification.

No production host, client data, signed DPA, vendor import specification or independent certification was reviewed. Provider residency, no-training and zero retention cannot be inferred from the code. Material project changes can invalidate this assessment.

Make the next review reproducible

Track evidence IDs, owners, dates, release/configuration identifiers, scope, results and exceptions. The companion metadata records hashes of selected local evidence and the report source/PDF. These identify the files; they do not certify correctness.

Professional review before deployment

Have German notarial counsel and the relevant privacy/security specialists validate the deployment-specific conclusions. Legal scope and technical adequacy must be rechecked before real-data use and after material changes.

REFERENCE LIBRARY / 1 OF 3

Privacy and AI law.

Primary sources reviewed on 30 October 2026. Click a reference title or an in-text source number to open the official source.

[S01] GDPR — Regulation (EU) 2016/679

European Union. Primary legal reference: Articles 5–6, 9–10, 12–22, 24–25, 28–36 and 44–49. EUR-Lex full-page retrieval was challenge-protected; indexed legal extracts and the EDPB sources below support the discussion.

[S02] EDPB — Respect individuals’ rights

European Data Protection Board. Rights, response periods and the limits of automatic decision-making.

[S03] EDPB — Data protection impact assessment

European Data Protection Board. High-risk processing, DPIA timing and prior consultation where residual high risk cannot be mitigated.

[S04] EDPB — Guidelines 07/2020: controller and processor

European Data Protection Board, final guidance. Role allocation, processing contracts, assistance and processor breach escalation.

[S05] EDPB — International data transfers

European Data Protection Board. Transfer criteria, adequacy, safeguards, SCCs and ongoing monitoring.

[S06] European Commission — AI Act and application timeline

Official overview updated 19 October 2026. Confirms the July 2026 AI Omnibus and revised high-risk application dates. Avoid relying on the original 2024 timetable alone.

[S07] AI Act Service Desk — Article 6

European Commission’s consolidated explorer, based on the 27 July 2026 text. High-risk classification, preparatory-task conditions and documentation/registration.

The engineering targets, role assignments and release gates are LexFlow-specific recommendations. Statutory applicability remains subject to the documented deployment and professional assessment.

REFERENCE LIBRARY / 2 OF 3

AI and cybersecurity.

Primary sources reviewed on 30 October 2026. Click a reference title or an in-text source number to open the official source.

[S08] AI Act Service Desk — Annex III

European Commission. Point 8(a): judicial-authority and comparable alternative-dispute-resolution uses. A legal-sector product label alone is insufficient for classification.

[S09] AI Act Service Desk — Article 4, AI literacy

European Commission’s amended text. Measures supporting staff AI literacy are required; guaranteeing each individual’s literacy level is not required.

[S10] European Commission — Cyber Resilience Act summary

Official explanation of scope, remote processing, manufacturer responsibilities and conformity routes; read with Regulation (EU) 2024/2847.

[S11] European Commission — Cyber Resilience Act timeline

Main obligations apply from 11 December 2027; Article 14 reporting applies from 11 September 2026. Role and product scope still need assessment.

[S12] European Commission — CRA reporting obligations

Official guidance dated 11 September 2026. 24-hour/72-hour notifications and distinct final-report triggers; Single Reporting Platform.

[S13] European Commission — NIS2 Directive

Directive (EU) 2022/2555. Sector/entity scope, risk management, supply chain and management accountability.

[S14] Commission Guidelines — NIS2 Article 4 and incident reporting

2023/C 328/02, paragraphs 19–20. General 24-hour/72-hour/one-month reporting sequence, ongoing-incident treatment and trust-service exception.

The engineering targets, role assignments and release gates are LexFlow-specific recommendations. Statutory applicability remains subject to the documented deployment and professional assessment.

REFERENCE LIBRARY / 3 OF 3

German duties and assurance.

Primary sources reviewed on 30 October 2026. Click a reference title or an in-text source number to open the official source.

[S15] BSI — NIS2 registration information

Federal Office for Information Security. German implementing law in force since 6 December 2025; current registration/reporting portal.

[S16] BNotO §26a — Inanspruchnahme von Dienstleistungen

German official legislation service. Provider selection, confidentiality, text-form commitments, subcontracting and the special consent rule in subsection (4); references §18 secrecy.

[S17] NotAktVV — Notarial files and registers

German official legislation service. In particular §5 electronic-record security and the applicable record-category retention rules. Archive-operator duties must not be confused with LexFlow’s role.

[S18] European Commission — eIDAS trust-service questions and answers

Qualified signatures, seals and trusted-list status under the amended eIDAS framework. Does not remove national notarial-form requirements.

[S19] ISO/IEC 27001:2022 and Amendment 1:2024

ISO. Information-security management system standard and current amendment. Certification must have a defined organizational and service scope.

[S20] ISO/IEC 27701:2025 — Privacy management

ISO. Current privacy information management system standard. A voluntary assurance route, not a substitute for GDPR duties.

[S21] ISO/IEC 42001:2023 — AI management systems

ISO. Management of AI risks and organizational governance. It does not establish that every product output is correct.

The engineering targets, role assignments and release gates are LexFlow-specific recommendations. Statutory applicability remains subject to the documented deployment and professional assessment.